IBM DB2HACK 2026

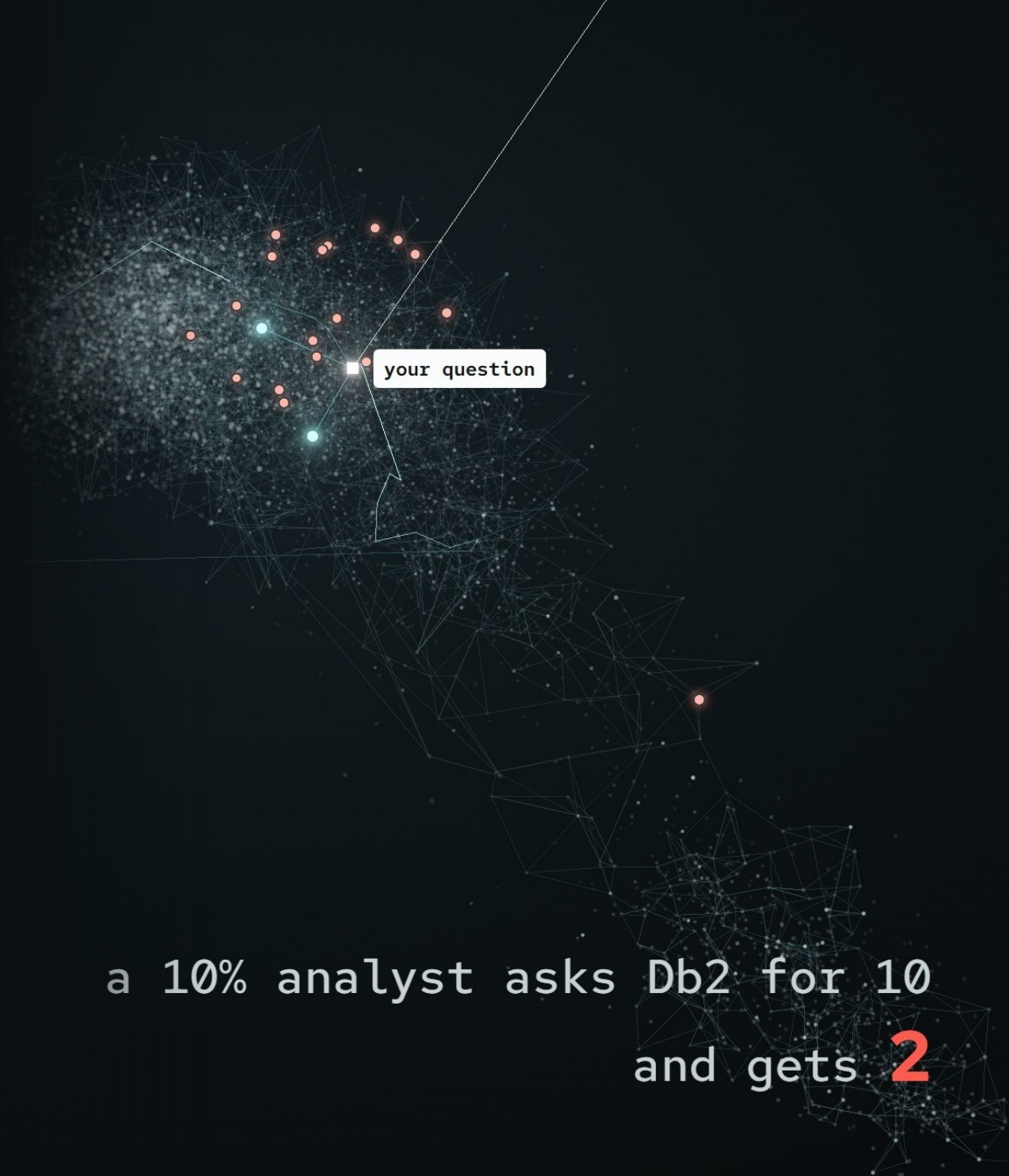
NEEDLE

Find the needle.

NEEDLE tells you which of your services a vague security report hits, inside IBM Db2.

Team Needlepoint · Kartikeya Lathi and William

IBM Db2 12.1.5



a 10% analyst asks Db2 for 10

and gets 2

A rumour in chat, and no CVE yet



#platform-sec

“the yaml loader we use … can run arbitrary code … no CVE number … are we exposed?”



Who is exposed?

Services, versions, since when



Who may know?

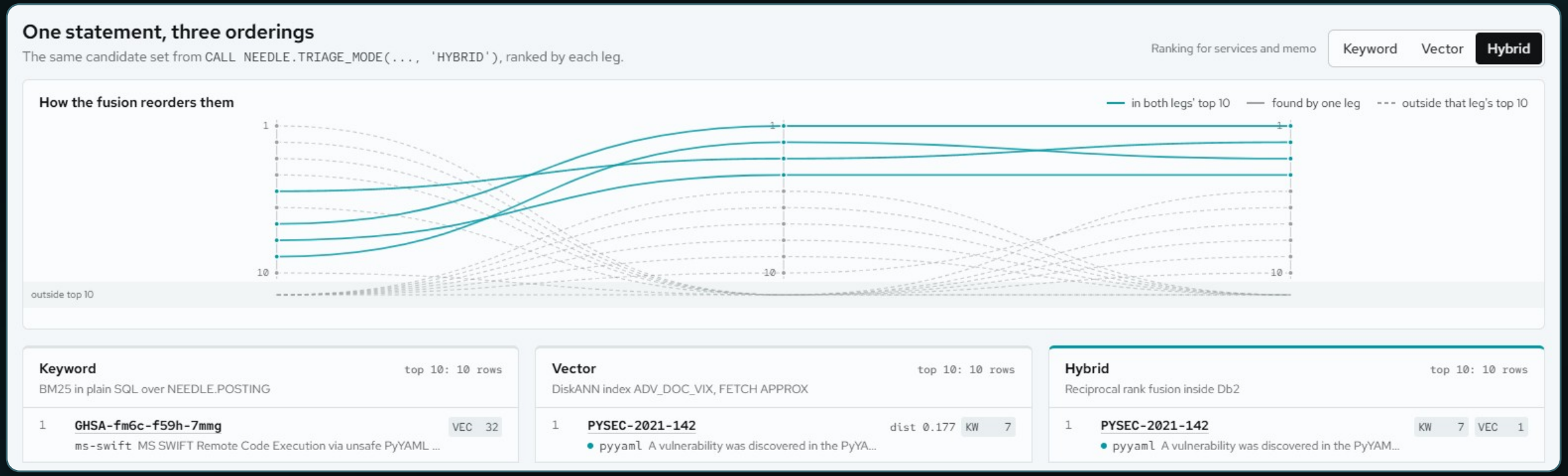
Embargoes, per analyst

One SQL PL call does the triage

BM25 + DiskANN + RRF
ranked and fused inside Db2

Row access control
applied per analyst by Db2

Temporal SBOM join
names services (synthetic fleet)



Live demo: 1 service affected now

2,448

days exposed

legacy-reporting

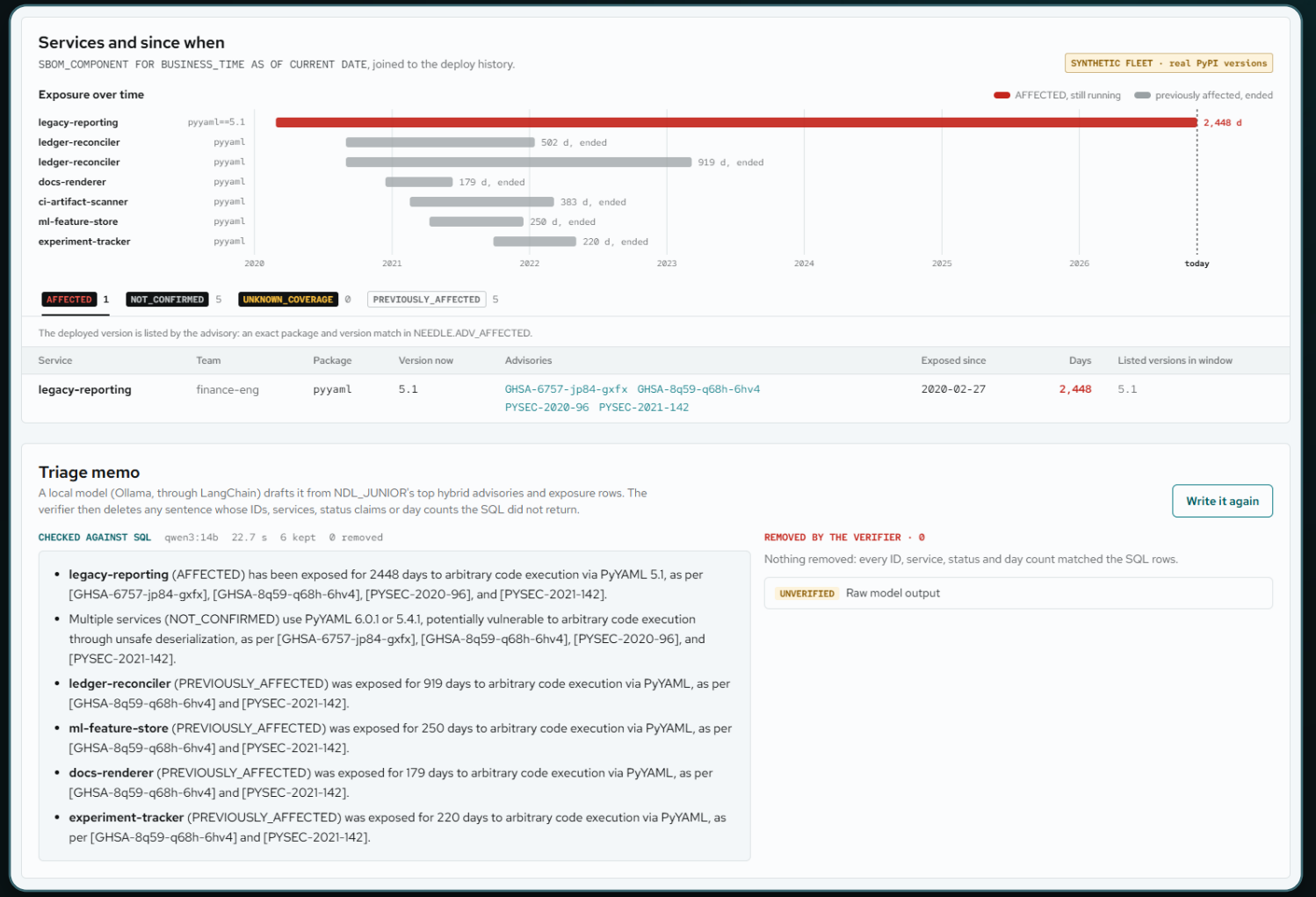
`pyyaml==5.1`

AFFECTED since 2020-02-27

5 NOT_CONFIRMED
5 PREVIOUSLY_AFFECTED

Memo checked against the SQL rows

SYNTHETIC FLEET · REAL ADVISORIES



Db2 decides who may know

NDL_SENIOR

GHSA-5x8w-8jj5-q52h

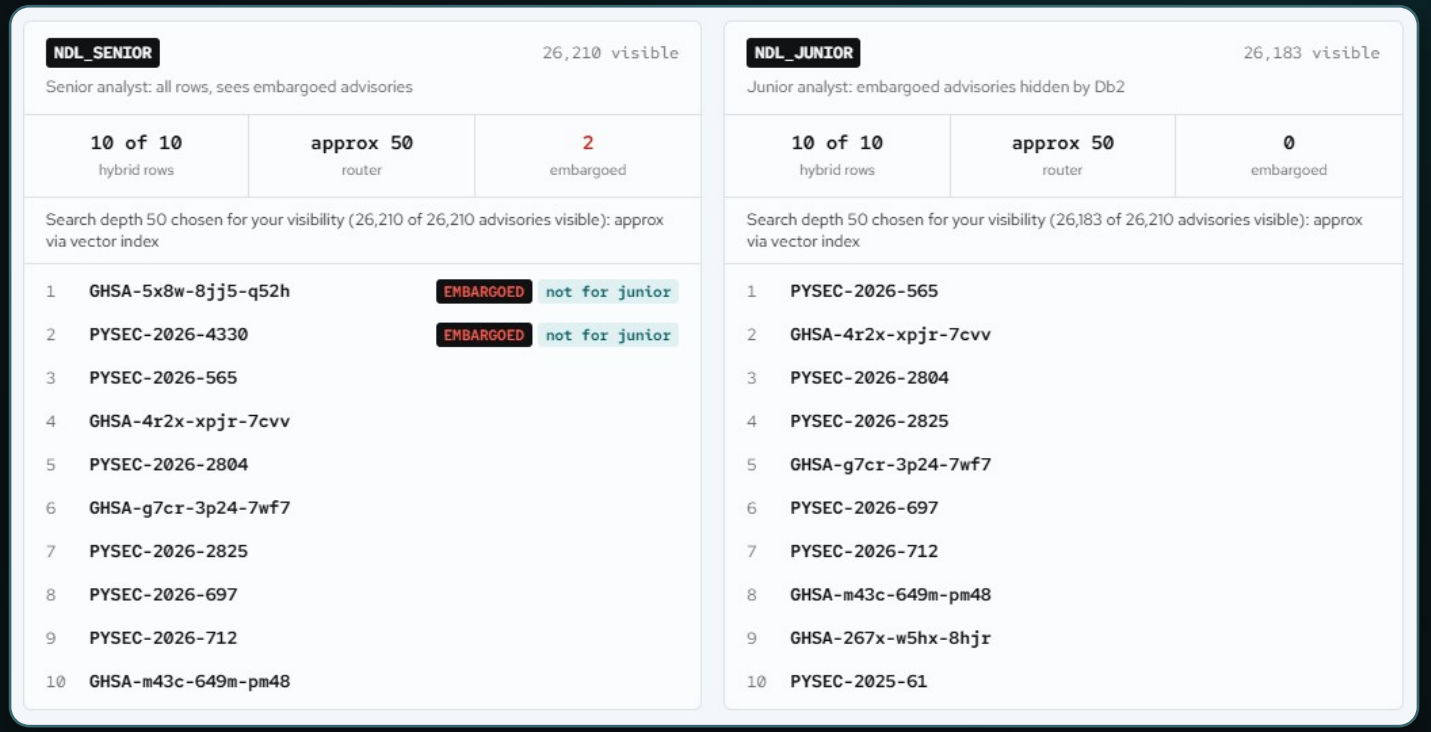
hybrid rank 1

NDL_JUNIOR

never sees it

not in rankings, documents, exposure or memo

Row access control removed it, not the app.



NDL_SENIOR — 26,210 visible

Senior analyst: all rows, sees embargoed advisories

10 of 10	approx 50	2
hybrid rows	router	embargoed

Search depth 50 chosen for your visibility (26,210 of 26,210 advisories visible): approx via vector index

1	GHSA-5x8w-8jj5-q52h	EMBARGOED not for junior
2	PYSEC-2026-4330	EMBARGOED not for junior
3	PYSEC-2026-565	
4	GHSA-4r2x-xpjr-7cvv	
5	PYSEC-2026-2804	
6	GHSA-g7cr-3p24-7wf7	
7	PYSEC-2026-2825	
8	PYSEC-2026-697	
9	PYSEC-2026-712	
10	GHSA-m43c-649m-pm48	

NDL_JUNIOR — 26,183 visible

Junior analyst: embargoed advisories hidden by Db2

10 of 10	approx 50	0
hybrid rows	router	embargoed

Search depth 50 chosen for your visibility (26,183 of 26,210 advisories visible): approx via vector index

1	PYSEC-2026-565
2	GHSA-4r2x-xpjr-7cvv
3	PYSEC-2026-2804
4	PYSEC-2026-2825
5	GHSA-g7cr-3p24-7wf7
6	PYSEC-2026-697
7	PYSEC-2026-712
8	GHSA-m43c-649m-pm48
9	GHSA-267x-w5hx-8hjr
10	PYSEC-2025-61

Pillow FlashPix rumour, no CVE

The finding: ask for 10, get 2

1
plan for every user

→

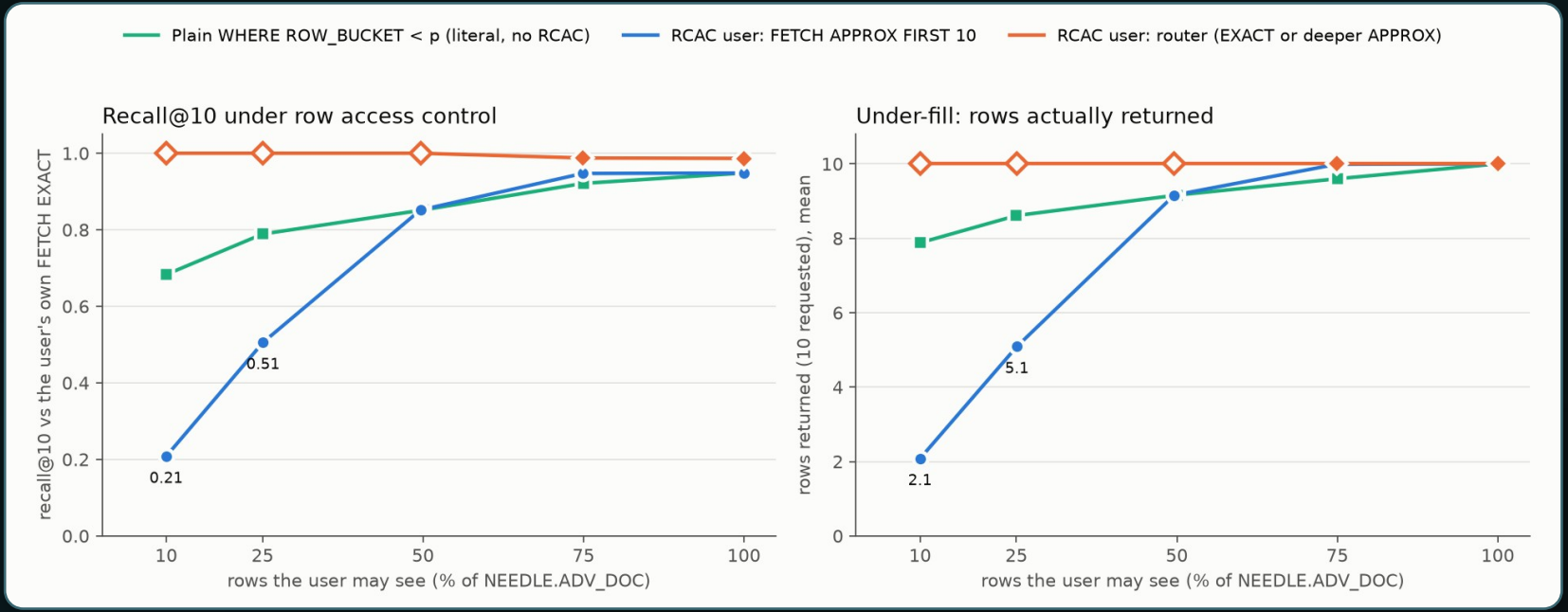
0.495
filter factor, all users

→

21
candidates for top 10

→

2.05
of 10 rows, 10 % analyst



recall@10, 10 % analyst

0.205
shared plan

0.765
literal control

Not an RCAC defect

89 held-out queries, Db2 12.1.5

The fix: a router per analyst

NDL_P10

2,616
of 26,210 visible

→

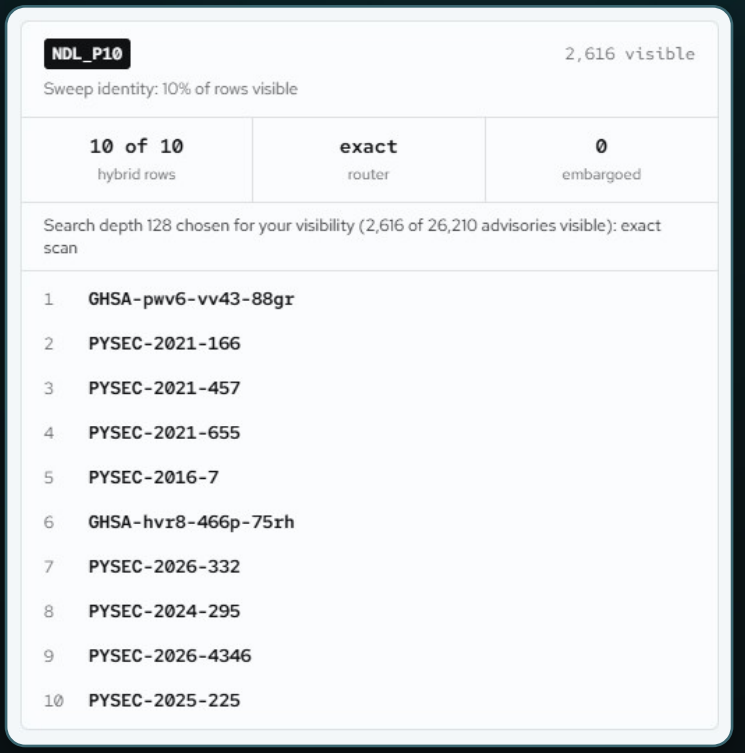
exact scan
router's choice

→

10 of 10
rows returned

0.987–1.000
held-out recall@10, 89 queries, 0 leaks

10 of 10
correlated visibility



The router restores recall and row count.

Performance and trust, measured

2.9 ms

DiskANN p50; exact 73.2 ms

53.5 ms

TRIAGE p50, RCAC on

27.2 ms

BM25 p50, was 244.8 ms

hit@10, paraphrases



Memo verifier removes claims the SQL did not return.

k as a literal: FETCH APPROX FIRST 10 — cost 501.8 · uses ADV_DOC_VIX

```
Access Plan:
-----------
    Total Cost:         501.797
    Query Degree:       1


            Rows
           RETURN
           (   1)
            Cost
             I/O
             |
             10
           TBSCAN
           (   2)
           501.797
           70.4381
             |
             10
           SORT
           (   3)
           501.797
           70.4381
             |
             10
           FETCH
           (   4)
           501.788
           70.4381
         /---+----\
       10          26210
     IXSCAN    TABLE: NEEDLE
     (   5)       ADV_DOC
     431.44         Q1
     60.4536
       |
      26210
  VECIDX: NEEDLE
    ADV_DOC_VIX
       Q1
```

Built on IBM Db2 12.1.5

DB2

- VECTOR
- VECTOR_DISTANCE
- DiskANN index
- FETCH APPROX/EXACT
- RCAC PERMISSION/MASK
- BUSINESS_TIME
- SQL PL
- JSON_TABLE
- MERGE
- EXPLAIN

STACK

- LangChain
- Haystack
- FastAPI
- React
- Ollama

REPO

github.com/wiiqz/IBM2026

PR

github.com/KunalGolaIBM/IBM_Db2_TechX_Project_Submission/pull/55

NEEDLEPOINT

Kartikeya Lathi · William